SPIKA TECH™

# NORMA DE SERVICIOS CLOUD

| HISTORIAL DEL DOCUMENTO | | | |
|---|---|---|---|
| **Versión** | **Resumen de modificaciones** | **Fecha de entrada** | **Sustituye a (Código, revisión)** |
| 01 | Primera versión del documento. | 26/02/2025 | N/A |

| REGISTRO DE FIRMAS | | | |
|---|---|---|---|
| **Función:** | **Elaborado por:** | **Revisado por:** | **Aprobado por:** |
| Departamento: | Responsable del SGSI | Dirección | Jefe de seguridad (o suplente) |
| Nombre: | David Pozo | Carlos Rodrigo | Carlos Zúñiga |
| Firma: | Firmado por POZO SANCHEZ DAVID - ***6992** el día 26/02/2025 | Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) | Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 26/02/2025 con un |
| Fecha: | 26/02/2025 | 26/02/2025 | 26/02/2025 |

## CONTENIDO

1 OBJETIVO ..... 5
2 ALCANCE ..... 5
3 NORMATIVA APLICABLE ..... 5
4 CONCEPTOS BÁSICOS ..... 5
4.1 RESPONSABLE DE LA INFORMACIÓN ..... 5
5 PROTECCIÓN DE SERVICIOS EN NUBE ..... 7
5.1 Modelo de responsabilidad compartida ..... 8
5.2 Medidas de seguridad ..... 9
5.2.1 PROTECCIÓN DE LAS INSTALACIONES E INFRAESTRUCTURAS ..... 9
5.2.2 GESTIÓN DEL PERSONAL ..... 9
5.2.3 PROTECCIÓN DE LOS EQUIPOS ..... 9
5.2.4 PROTECCIÓN DE LAS COMUNICACIONES ..... 10
5.2.5 PROTECCIÓN DE LOS SOPORTES DE INFORMACIÓN ..... 10
5.2.6 PROTECCIÓN DE LAS APLICACIONES ..... 10
5.2.7 CALIFICACIÓN DE LA INFORMACIÓN ..... 11
5.2.8 LIMPIEZA DE DOCUMENTOS ..... 11
5.2.9 COPIAS DE SEGURIDAD ..... 11
5.2.10 PROTECCIÓN DE LOS SERVICIOS ..... 12
5.2.11 AUDITORÍA DE PRUEBAS DE PENETRACIÓN (PENTESTING) ..... 12
5.2.12 TRANSPARENCIA ..... 12
5.2.13 CIFRADO Y GESTIÓN DE CLAVES ..... 13
5.2.14 JURISDICCIÓN DE LOS DATOS ..... 14
5.2.15 SERVICIOS CERTIFICADOS ..... 16
5.2.16 GESTIÓN DE CONTINUIDAD Y RESILIENCIA DE OPERACIONES ..... 16
5.2.17 CONTROL DE CAMBIOS Y GESTIÓN DE CONFIGURACIÓN ..... 16
5.2.18 EXPLOTACIÓN ..... 16
5.2.19 CONTROL DE ACCESOS ..... 17
5.2.20 INTEROPERABILIDAD Y PORTABILIDAD ..... 17
5.2.21 INFRAESTRUCTURA Y VIRTUALIZACIÓN ..... 17
5.2.22 REGISTRO Y MONITORIZACIÓN ..... 18
5.2.23 GESTIÓN DE INCIDENTES ..... 18
5.3 Contratación y Acuerdos de Nivel de Servicio ..... 19

6 REGISTROS Y ARCHIVOS ..... 23
7 REFERENCIAS ..... 23
8 ANEXOS ..... 24
8.1 Relación de medidas de seguridad y el modelo de responsabilidad compartida .... 24

# 1 OBJETIVO

La presente normativa específica diferentes aspectos relacionados con los requisitos de seguridad a considerar en un servicio desplegado en la nube, independientemente del proveedor del servicio, garantizándose la disponibilidad, integridad, confidencialidad, autenticidad y trazabilidad de todos los datos almacenados o transmitidos y de los procesos que se llevan a cabo, considerando las diferentes modalidades permitidas en función de las necesidades. En este sentido, cuando SPIKA TECH utilice recursos externos (servicios, productos, instalaciones o personal), mantendrá la plena responsabilidad de los riesgos para la información tratada o los servicios prestados, debiendo adoptar las medidas necesarias para ejercer su responsabilidad y mantener el control en todo momento.

Este documento tiene como objetivo establecer el conjunto de medidas de seguridad para los servicios que se encuentran en la nube que se gestionan y utilizan en SPIKA TECH.

# 2 ALCANCE

La normativa descrita en este documento proporciona a todo el personal que lleva a cabo actividades relacionadas con la gestión y utilización de los servicios en la nube, independientemente del proveedor, el marco de seguridad de la protección de dichos servicios que se emplean en SPIKA TECH para garantizar una adecuada seguridad de la información.

# 3 **NORMATIVA** APLICABLE

Es aplicable toda la normativa establecida en el documento de **RGS_1 NORMATIVA APLICABLE.xlsx.**, que se actualizara de forma periódica Las Políticas, Normas y Procedimientos dentro del alcance del SGSI, se actualizarán, si procede, en base a los cambios normativos que pudieran afectar.

# 4 CONCEPTOS BÁSICOS

## 4.1 RESPONSABLE DE LA INFORMACIÓN

A continuación, se detallan los conceptos básicos que debe tener en cuenta el usuario.

Modelos de implementación en la nube:

- **Nube Pública:** La infraestructura de esta nube está mantenida y gestionada por terceras personas no vinculadas con SPIKA TECH. Este tipo de entornos proporcionan recursos de forma abierta a diferentes organizaciones que hayan establecido este tipo de relación contractual con el proveedor.

- **Nube Privada:** La infraestructura de esta nube o servicios provistos son completamente dedicados a SPIKA TECH, que controla qué aplicaciones debe ejecutarse y dónde. Puede ser propiedad, ser administrado y operado por SPIKA TECH, un tercero o alguna combinación de ellos, y puede existir dentro o fuera de las instalaciones.

- **Nube Híbrida:** Los servicios se ofrecen de forma pública y privada. Se es propietario de unas partes y se comparten otras, aunque de una manera controlada.

- **Nube Comunitaria:** La infraestructura de esta nube o servicios provistos son compartidos en comunidad cerrada por varias organizaciones que comparten un interés común.

A continuación, de desarrollan los modelos básicos de servicio en la nube.

- **Infraestructura como Servicio (IaaS):** Se encarga de entregar una Infraestructura al usuario, proporcionando recursos de procesamiento y almacenamiento mediante la red, sin ningún otro valor añadido. El proveedor de servicios en la nube es responsable de la administración de la infraestructura y SPIKA TECH tiene el control sobre los sistemas operativos, almacenamiento y aplicaciones desplegadas, así como el control de los componentes de red. Las instalaciones físicas y la infraestructura de hardware forman la base de un modelo IaaS.

- **Plataforma como Servicio (PaaS):** Consiste en la entrega de una plataforma a SPIKA TECH. SPIKA TECH no administra ni controla la infraestructura, pero sí que tiene el control sobre las aplicaciones instaladas y su configuración. En definitiva, el usuario de servicios en la nube solo tiene acceso a la plataforma, no la infraestructura subyacente.

- **Software como Servicio (SaaS):** Se trata de un modelo de distribución de software en el que las aplicaciones están alojadas por un proveedor de servicio en la nube y

son puestas a disposición de los usuarios a través de red. El usuario encuentra en la nube las herramientas con las que se puede implementar todos los procesos necesarios, donde SPIKA TECH ni administra ni controla la infraestructura en que se basa el servicio empleado. En definitiva, es el proveedor quién dispone, sin intervención de SPIKA TECH, de la capacidad de administrar o controlar la infraestructura en la que se basa el servicio prestado.

## 5 PROTECCIÓN DE SERVICIOS EN NUBE

El uso de los servicios en la nube introduce una serie de riesgos que son necesarios controlar para garantizar que este servicio tecnológico se preste conforme a los requisitos legales exigibles y los requisitos de seguridad que SPIKA TECH establece como necesarios.

El cumplimiento de los requisitos legales y de seguridad depende del modelo de despliegue, la categoría de servicio y la calificación de la información ubicada en la nube.

En el supuesto de que sea SPIKA TECH el propietario y administrador de la infraestructura sobre las que se despliegan los servicios en la nube, la completa adecuación efectiva a la normativa vigente es responsabilidad de SPIKA TECH.

En cualquier caso, la responsabilidad del cumplimiento de la ISO o de cualesquiera otras normas de aplicación, así como del correcto tratamiento de los datos en términos generales, es responsabilidad de la organización propietaria de la información.

Los sistemas que suministran un servicio en la nube a SPIKA TECH deberán cumplir con el conjunto de medidas de seguridad en función del modelo de servicio en la nube que presten: Software como Servicio (Software as a Service, SaaS), Plataforma como Servicio (Platform as a Service, PaaS) e Infraestructura como Servicio (Infrastructure as a Service, IaaS) definidas en las guías CCN-STIC que sean de aplicación.

Cuando se utilicen servicios en la nube suministrados por terceros, los sistemas de información que los soportan deberán ser conformes con la ISO o cumplir con las medidas desarrolladas en una guía CCN-STIC

Cuando se utilicen servicios en la nube suministrados por terceros, estos deberán estar certificados bajo una metodología de certificación reconocida por el Organismo de Certificación del Esquema Nacional de Evaluación y Certificación de Seguridad de las Tecnologías de la Información.

Si el servicio en la nube es un servicio de seguridad deberá cumplir con los requisitos establecidos en el control sobre componentes certificados.

## 5.1 Modelo de responsabilidad compartida

Los servicios en la nube adoptan un modelo de responsabilidad compartida en el que pueden existir diferentes actores con diferentes responsabilidades. En esta norma se han resumido en dos: cliente y proveedor. Siendo el cliente SPIKA TECH y el proveedor aquella organización que ofrezca el servicio en la nube, total o parcialmente.

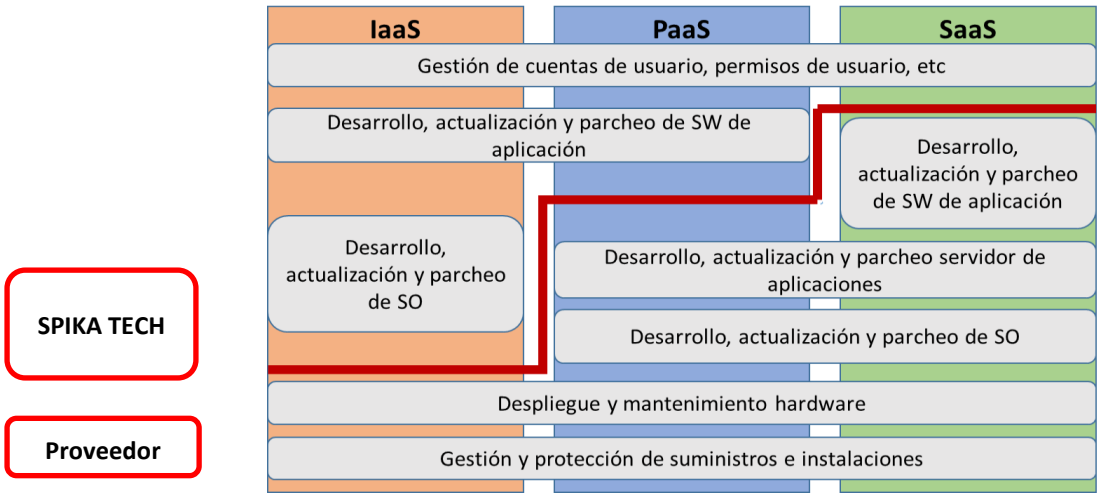
En caso de existir más actores debe analizarse qué medidas de seguridad son responsabilidad de cada una de las partes.

Así, podemos hablar de seguridad de la nube y seguridad en la nube:

- **Seguridad de la nube:** El proveedor es responsable de la seguridad de los servicios que provea a SPIKA TECH, así como de cumplir aquellos acuerdos de nivel de servicio que establezca. Abarca la seguridad del Hardware, el Software, las redes y las instalaciones que ejecutan servicios en la nube.

- **Software en la nube:** La responsabilidad de SPIKA TECH está limitada a la seguridad de los servicios que despliegue sobre la nube en que no sea propietario del proveedor, así como de las configuraciones que establezca, en base a sus capacidades dependiendo de la categoría del servicio que haya contratado.

A partir de las categorías de servicio definidas, se desarrollan las medidas de seguridad que podrán estar asociadas a SPIKA TECH y al proveedor y que estarán recogidas entre otros, en los Acuerdos de Nivel de Servicio (SLA).



## 5.2 Medidas de seguridad

SPIKA TECH debe analizar qué tipos de datos va a trasladar a la en la nube, cuál es el tratamiento que se va a hacer de éstos y qué requisitos de ubicación se contempla.
SPIKA TECH debe evaluar periódicamente que el proveedor de la nube ha sido auditado por un tercero y posea las certificaciones de cumplimiento que los servicios de SPIKA TECH requieran.
Cuando se utilicen servicios en la nube, los sistemas de información que los soportan deben disponer de la certificación de conformidad con la ISO 27001 o con otra certificación equivalente que pueda demostrar que se cumplen con los requisitos de seguridad correspondientes.
El contrato recogerá los requisitos de acuerdo a lo recogido en la normativa vigente de contratación pública y en la el **"Procedimiento de adquisición de nuevos componentes TIC".**

### 5.2.1 PROTECCIÓN DE LAS INSTALACIONES E INFRAESTRUCTURAS

Las medidas de seguridad relativas a este apartado estarán cubiertas por el proveedor. En caso de que la provisión se realice desde una nube privada "on premise", será SPIKA TECH el responsable de su aplicación.

### 5.2.2 GESTIÓN DEL PERSONAL

Las medidas relativas a la seguridad en la gestión del personal (perfiles de puestos de trabajo, concienciación, formación, funciones y obligaciones) serán cubiertas por el proveedor en lo relativo a la provisión de los servicios en la nube. No obstante, SPIKA TECH deberá aplicar estas medidas de protección en relación con el personal relacionado con estos servicios.

### 5.2.3 PROTECCIÓN DE LOS EQUIPOS

Las medidas relativas al bloqueo de puesto de trabajo, protección de portátiles, etc., serán cubiertas por el proveedor en lo relativo a la provisión de los servicios en la nube. No obstante, SPIKA TECH tendrá que aplicar estar medidas respecto a los equipos relacionados con estos servicios.

### 5.2.4 PROTECCIÓN DE LAS COMUNICACIONES

Las medidas relativas a la protección perimetral, confidencialidad, integridad, autenticidad, segregación de redes, entre otras, serán cubiertas por el proveedor en lo relativo a la provisión de los servicios en la nube. No obstante, SPIKA TECH aplicará medidas respecto a las comunicaciones que realice sobre estos servicios.

Dado que se aplica el principio de seguridad en todas las capas, SPIKA TECH es responsable de establecer las protecciones perimetrales necesarias para proteger los servicios que corren sobre la infraestructura contratada, mientras que el proveedor es el responsable de implementar las medidas de protección perimetral para el servicio que ofrece.

Debe aplicarse mecanismos criptográficos para la protección de la confidencialidad e integridad de la información en tránsito mediante la utilización de VPN que hayan superado con éxito un proceso de cualificación. En este caso, el canal de comunicaciones aportará una autenticación de extremo a extremo. La utilización de cifrado online será obligatoria siempre que se envíe información fuera del sistema que provee la infraestructura.

Todo el tráfico entrante y saliente debe pasar por la VPN y no debe existir ningún tráfico fuera de ella que pueda suponer un canal encubierto.

La protección de las comunicaciones será aplicable, tanto a las comunicaciones con entidades externas, como a las establecidas dentro de la infraestructura en la nube, cuando se transmita por medios compartidos.

### 5.2.5 PROTECCIÓN DE LOS SOPORTES DE INFORMACIÓN

Las medidas relativas al etiquetado, custodia, transporte, borrado y destrucción serán cubiertas por el proveedor en lo relativo a la provisión de los servicios en la nube. No obstante, SPIKA TECH aplicará las medidas de seguridad necesarias para los soportes relacionados con estos servicios.

### 5.2.6 PROTECCIÓN DE LAS APLICACIONES

Las medidas relativas al desarrollo seguro, pruebas de aceptación y puesta en servicio serán cubiertas por el proveedor en lo relativo al software relacionado con la provisión de los

servicios en la nube. No obstante, SPIKA TECH deberá aplicar medidas de seguridad respecto al software de su competencia relacionado con los servicios.

#### 5.2.7 CALIFICACIÓN DE LA INFORMACIÓN

En el supuesto en que el proveedor proporcione mecanismos que permitan el etiquetado de la información alojada en la nube, SPIKA TECH podrá alinear su "**Procedimiento de etiquetado y clasificación de la información".**

#### 5.2.8 LIMPIEZA DE DOCUMENTOS

El procedimiento de limpieza de metadatos de documentos propios de la organización es responsabilidad de SPIKA TECH y debe seguir lo establecido en el "**Procedimiento de etiquetado y clasificación de la información".**

#### 5.2.9 COPIAS DE SEGURIDAD

Cuando la realización de las copias de seguridad sea responsabilidad del proveedor, SPIKA TECH debe solicitar información sobre el procedimiento de copias y las pruebas de respaldo implementadas, como mínimo de los siguientes aspectos:

- Alcance de los respaldos
- Política de copias de seguridad
- Medidas de cifrado de información en respaldo
- Realización de pruebas de restauración
- Traslado de copias de seguridad
- Las copias de seguridad consistirán en imágenes de los sistemas/máquinas (snapshots) y/o copias de archivos que permitan recuperar datos de una antigüedad determinada conforme a la normativa aplicable. Estas copias abarcan la información de SPIKA TECH, aplicaciones, sistema operativo, datos de servicios y equipos, claves, etc. Deben tener el mismo nivel de seguridad que los datos originales.

### 5.2.10 PROTECCIÓN DE LOS SERVICIOS

La aplicación de medidas para la protección del correo electrónico de las amenazas propias de este medio es responsabilidad de SPIKA TECH, salvo que el proveedor proporcione la provisión de correo electrónico.

La protección de los servicios y aplicaciones web de las amenazas propias de este medio son cubiertas por el proveedor en lo relativo a la provisión de los servicios en la nube en la modalidad de software como servicio (SaaS), en caso contrario será responsabilidad de SPIKA TECH.

La aplicación de las medidas relativas a la protección frente a la denegación de servicio debe estar implementado por el proveedor, salvo que la provisión de los servicios sea en un entorno de nube privada “on premise”, siendo responsabilidad de SPIKA TECH.

### 5.2.11 AUDITORÍA DE PRUEBAS DE PENETRACIÓN (PENTESTING)

El servicio en la nube debe superar con éxito la auditoría de pentesting de caja negra en la que se comprueban la ausencia de vulnerabilidades públicas que permitan comprometer la información manejada o el servicio prestado.

Todos los sistemas que manejen información no clasificada serán objeto de auditorías de seguridad, según la normativa de aplicación. En esta auditoría se evalúan los requisitos que son responsabilidad del proveedor de servicios en la nube.

### 5.2.12 TRANSPARENCIA

El proveedor del servicio de seguridad en la nube debe ser capaz de proporcionar a SPIKA TECH:

- El listado de las herramientas de seguridad de las que dispone, incluyendo aquellas destinadas a la monitorización, análisis, recuperación y notificación de incidentes de seguridad.

- La descripción o especificación de la virtualización utilizada y del nivel y mecanismos de segregación de sus datos o aplicaciones alojadas en la nube.

- El listado y especificación de los mecanismos y procedimientos de borrado seguro de la información almacenada por el proveedor. Estos mecanismos de borrado seguro deben eliminar la información de manera que no sea recuperable una vez que finalice su uso.

- La ubicación geográfica de los datos, antes y durante el suministro del servicio.

- El acceso y análisis de los logs, registros de acceso y cualquier otra información que pudiera ser solicitada para garantizar el cumplimiento de las obligaciones legales. En caso de incidente de seguridad, toda la información requerida de los equipos físicos, dispositivos de red, servicios compartidos y dispositivos de seguridad debe ser entregada a SPIKA TECH.

#### 5.2.13 CIFRADO Y GESTIÓN DE CLAVES

El servicio debe disponer de mecanismos de cifrado que permitan que la información del usuario esté protegida, en tránsito y en reposo, para que no pueda ser leída o modificada en caso de acceso ilegítimo.
El proveedor debe cumplir uno de los siguientes casos:

- Ser capaz de garantizar el funcionamiento de los mecanismos de cifrado sin que las claves de cifrado sean almacenadas en la nube. Estas estarán en disposición de SPIKA TECH quien es el encargado de su gestión y almacenamiento.

- Almacenar las claves de cifrado en módulos de seguridad de software, no accesibles por terceros.

- En el caso de utilizar dispositivos hardware, los mismos deben estar cualificados por el CCN e incluidos en el CPSTIC (Catálogo de Productos y Servicios STIC) del CCN. En este caso, el proveedor debe poner en conocimiento de SPIKA TECH las medidas implementadas para proteger las claves criptográficas durante todo su ciclo de vida. En caso contrario, es responsabilidad de SPIKA TECH su custodia y protección.

### 5.2.14 JURISDICCIÓN DE LOS DATOS

El proveedor debe informar a SPIKA TECH sobre la ubicación geográfica de sus datos (incluido copias de seguridad y almacenamiento de logs), antes y durante el suministro del servicio.

Se debe cumplir con la normativa de protección de datos vigente y, en especial, con las garantías necesarias para las transferencias de datos personales a terceros países u organizaciones internacionales. No obstante, siempre que sea posible se evitará la transferencia internacional de datos, abogando por la contratación dentro del Espacio Económico Europeo y que cumplan con la normativa de Protección de Datos.

| | Descripción |
|---|---|
| **Análisis de Riesgos** | Cuando el tratamiento de los datos no entrañe un alto riesgo se debe realizar análisis de riesgos para determinar las medidas de seguridad y técnicas de conformidad al artículo 32 RGPD. |
| **Evaluación de Impacto de Protección de Datos** | Cuando el tratamiento de datos personales pueda resultar un alto riesgo para los derechos y libertades de los ciudadanos, SPIKA TECH debe realizar una Evaluación de Impacto de Protección de Datos antes de iniciar con el tratamiento de los datos.<br><br>La EDPB (European Data Protection Board) reitera que la implementación de servicios en la nube por parte de organismos públicos con frecuencia desencadena un alto riesgo. |
| **Roles y responsabilidades determinadas e inequívocas** | Garantizar que las funciones de las partes involucradas estén clara e inequívocamente determinadas y definidas con precisión en el contrato. SPIKA TECH debe establecer claramente su papel con el uso de los servicios en la nube. |
| **Transferencias internacionales** | Analizar si una legislación de un tercer país sería aplicable al Proveedor y daría lugar a la posibilidad de atender solicitudes de acceso a los datos almacenados por el proveedor en el Espacio Económico Europeo. Por lo tanto, SPIKA TECH debe evaluar:<br><br>• Ley estatal a la que está sujeto el proveedor. |

| | |
|---|---|
| | • Si el proveedor está bajo la obligación legal de proporcionar acceso a los datos a las autoridades de otros terceros países.<br>• Si dichas solicitudes de acceso podrían cumplirse de conformidad al RGPD, es decir: con una base legal válida y una justificación para la transferencia.<br><br>Las transferencias internacionales deben cumplir con lo dispuesto en el capítulo V del RGPD. Ante una transferencia internacional de datos personales, SPIKA TECH debe proporcionar instrucciones al proveedor para identificar y aplicar las medidas complementarias apropiadas para garantizar la conformidad al RGPD. |
| **Encargado de tratamiento** | SPIKA TECH debe establecer disposiciones claras y exhaustivas estipuladas en el contrato celebrado con el proveedor de las medidas organizativas y técnicas. SPIKA TECH debe definir su papel en el tratamiento de los datos y su relación con el proveedor y especificar los controles de seguridad aplicados por el encargado y las medidas a tomar para mitigar los riesgos. |
| **Delegado de Protección de Datos** | Se recomienda la implicación y consulta al DPD para establecer las cláusulas en la contratación. El DPD debe desempeñar un papel activo en el análisis y negociación de los contratos ofrecidos por los proveedores. |
| **Cooperar con otros organismos públicos en la negociación con los proveedores** | Cuando varios organismos públicos intentan cooperar en la negociación con el proveedor o si se negocia los mismos servicios en nombre de varios organismos públicos, el desequilibrio en la negociación parece reducirse. |
| **Revisión / Auditoría** | Es necesario revisar y reevaluar periódicamente la EIPD y la evaluación de riesgos, ya que los servicios en la nube son dinámicos y están sujetos a cambios continuos. |

### 5.2.15 SERVICIOS CERTIFICADOS

El producto o productos que suministren la funcionalidad principal del servicio o formen parte de su arquitectura de seguridad, deberán disponer de una certificación funcional de seguridad o una evaluación STIC adecuada que cumpla con los requisitos correspondientes.

### 5.2.16 GESTIÓN DE CONTINUIDAD Y RESILIENCIA DE OPERACIONES

SPIKA TECH, para la realización del Análisis de Impacto (BIA), identificará los requisitos de disponibilidad que le serán de aplicación a los servicios proporcionados por la nube y verificará que se corresponden con los contratados al proveedor. En el caso de que la provisión se realice desde una nube privada “on premise”, será SPIKA TECH responsable de su aplicación.

### 5.2.17 CONTROL DE CAMBIOS Y GESTIÓN DE CONFIGURACIÓN

Para la configuración de seguridad (bastionado) del equipamiento, en caso de que SPIKA TECH se haya acogido a un Perfil de Cumplimiento Específico se seguirán las pautas recogidas en las guías de configuración del perfil de aplicación.

Para la realización de las tareas de mantenimiento y la gestión de los cambios, SPIKA TECH definirá las responsabilidades y protocolos de actuación con el proveedor, previniendo de este modo paradas o errores imprevistos, que pudieran afectar a la prestación de servicios.

### 5.2.18 EXPLOTACIÓN

Para el mantenimiento del inventario de activos, se tendrá en cuenta la existencia de servicios de nube, y que en función de la modalidad de nube podrán ser:

- En el caso de un servicio SaaS, la solución en la nube se reflejará como un activo de servicios externos.

- En el caso de servicios PaaS y IaaS se reflejarán los activos sobre los que se tienen control. Pudiéndose hacer uso de las herramientas de inventario que proporcione el proveedor para complementar su propio inventario.

- En caso de que la provisión de los servicios se realice desde una nube privada “on premise”, SPIKA TECH reflejará en el inventario de activos todos los activos involucrados en la prestación de los servicios.

### 5.2.19 CONTROL DE ACCESOS

SPIKA TECH tendrá en cuenta que el proveedor disponga de registros de actividad de los usuarios que permiten monitorizar, analizar, investigar y documentar acciones indebidas o no autorizadas, tanto a nivel operativo como de administración. Por tanto, se establecerá con el proveedor la responsabilidad sobre los registros de actividad de los usuarios, estableciendo obligaciones en cuanto a su configuración, la consolidación periódica de datos, la retención de los registros y respecto a los mecanismos implementados para la protección de los registros de actividad.

Permitir el acceso y análisis de los diferentes registros (logs), registros de acceso y cualquier otra información que pudiera ser solicitada para garantizar el cumplimiento de las obligaciones legales. En caso de incidente de seguridad, toda la información requerida (configuración, logs, etc.) de los equipos físicos, dispositivos de red, servicios compartidos y dispositivos de seguridad debe ser entregada a SPIKA TECH.

Cuando SPIKA TECH se haya acogido a un Perfil de Cumplimiento Específico para la configuración de las medidas relativas al control de acceso a los recursos se seguirán las pautas descritas en las guías de configuración asociadas al perfil de aplicación.

El proceso de identificación y autenticación de los usuarios se basa en el empleo de uno o varios de los siguientes factores, en función del nivel de seguridad requerido: algo que se sabe, algo que se tiene y algo que se es. Se debe establecer un número máximo de intentos de autenticación, de cara a evitar ataques de autenticación por fuerza bruta.

### 5.2.20 INTEROPERABILIDAD Y PORTABILIDAD

Se debe garantizar la migración segura de las operaciones/servicios/datos desde la nube de un proveedor a otro preservando la interoperabilidad y disponibilidad de los servicios en la nube. Se debe evitar por parte de SPIKA TECH una dependencia hacia un determinado fabricante o tecnología.

### 5.2.21 INFRAESTRUCTURA Y VIRTUALIZACIÓN

La infraestructura virtualizada debe tener en cuenta los siguientes puntos:

- Definición de zonas de seguridad que deben estar separadas.
- En qué casos SPIKA TECH y terceros deben estar (criptológica, lógica o físicamente) segregados.
- Qué relaciones de comunicación y qué redes y protocolos de aplicación están permitidos en cada caso.
- Cómo el tráfico de datos para administración y monitorización está segregado en cada nivel de red.
- Qué comunicaciones internas o entre distintas redes están permitidas.
- En todos los puntos anteriores se debe emplear el principio de denegación total por defecto.
- Además, deberá segregarse entornos de producción y no producción.
- Se implementarán medidas de bastionado para los componentes del sistema, hosts y sistemas operativos, hipervisores o control de infraestructura, acorde a las mejores prácticas de cada fabricante y a los Procedimientos de Empleo Seguro, en caso de productos cualificados/aprobados. Deben además existir controles técnicos de verificación de la configuración como parte de la base de seguridad.

#### 5.2.22 REGISTRO Y MONITORIZACIÓN

El proveedor dispondrá de herramientas de prevención o detección de intrusión. En el caso de que los servicios se encuentren soportados por una nube privada “on premise” será SPIKA TECH quien tendrá que implementar estas funcionalidades.

#### 5.2.23 GESTIÓN DE INCIDENTES

La gestión y respuesta a incidentes debe ser considerado como un proceso global y no como algo concreto de un sistema en la nube. Se ha de seguir con lo establecido en el “**Procedimiento de gestión de Incidentes**”.

Los propios proveedores disponen de documentos de buenas prácticas, útiles en la planificación de la respuesta a incidentes.

En caso de incidente grave, el proveedor debe facilitar toda la información disponible a SPIKA TECH. Por ello, es fundamental recoger esta necesidad en una cláusula en el contrato con el proveedor.

Dado que no hay posibilidad de aislamiento físico en la nube, es necesario considerar las soluciones de protección de equipos finales, así como los productos EDR que tienen capacidades de aislamiento (sandboxing). Si los sistemas no se pueden aislar fácilmente y son críticos para el negocio, es importante obtener algún tipo de aprobación documentada a nivel ejecutivo para la excepción a dicho sistema que no se puede aislar y poder demostrar la debida diligencia en la actuación.

Por último, respecto a las medidas adecuadas relativas a la cadena de custodia y preparación del análisis forense, SPIKA TECH debe evitar que se elimine información valiosa para facilitar el proceso de investigación y permitir la recuperación. En los entornos en nube existen muchas tareas automatizadas que pueden provocar que se pierda información relevante, por lo que SPIKA TECH debe solicitar al proveedor que suspenda los procesos automáticos o que realice medidas concretas durante el proceso de análisis de lo sucedido.

Mantener una adecuada cadena de custodia documentada es fundamental para el caso de determinar el alcance y responsabilidades jurídicas o de cumplimiento, así como para que las pruebas de los análisis forenses sean válidas ante un juzgado.

## 5.3 Contratación y Acuerdos de Nivel de Servicio

Cuando se contrate con un proveedor de servicios en la nube, SPIKA TECH debe establecer una serie de condiciones contractuales en la prestación del servicio. Asimismo, SPIKA TECH debe definir la calidad del servicio contratado mediante un Acuerdo de Nivel de Servicio.

SPIKA TECH tiene la obligación de requerir al proveedor de los servicios en la nube que provea sistemas que dispongan de la certificación de conformidad con normativa relevante en seguridad, como puede ser la ISO 27001 o el ENS.

Estos aspectos se deben regular con carácter previo a la contratación, en las ofertas y contratos realizados.

Es responsabilidad del proveedor implementar todos los mecanismos para garantizar el cumplimiento de los compromisos adquiridos y realizar pruebas periódicas para evaluar el correcto funcionamiento.

SPIKA TECH debe realizar un análisis para determinar cuáles son los umbrales adecuados para satisfacer sus necesidades de continuidad y disponibilidad, y exigirlos al proveedor a través del Acuerdo de Nivel de Servicio.

SPIKA TECH debe tener en cuenta las siguientes cláusulas:

| Clausulado de contrato | Contenido |
|---|---|
| **Descripción del Servicio** | Descripción detallada del servicio que el proveedor va a proporcionar, incluyendo los acuerdos de nivel de servicio. |
| **Tipo de servicio e infraestructura** | Descripción del tipo de servicio e infraestructura a contratar. |
| **Dimensionado del servicio** | Descripción de los recursos que conforman el servicio |
| **Capacidad** | Definir las desviaciones de carga que el proveedor debe asumir. Se tienen que definir tiempos de notificación en el caso de que se detecte insuficiencia de recursos. |
| **Disponibilidad** | Establecer porcentajes de disponibilidad del servicio en función de la criticidad del mismo, identificándose si hubiera períodos críticos en los que se requieren mayores niveles de disponibilidad. Se debe definir tiempos de recuperación acordes a la categoría del Sistema. |
| **Peticiones de cambio e incidentes** | Definir los tiempos de respuesta y resolución, así como el horario de atención a peticiones de cambio realizadas por SPIKA TECH o respecto a los incidentes reportados automática o manualmente. |

| | |
|---|---|
| **Responsabilidades y obligaciones** | Definir las responsabilidades involucradas en la prestación del servicio. |
| **Registro de actividad** | Definir las responsabilidades respecto a los registros de actividad. |
| **Gestión de incidentes** | Establecer los flujos de información y responsables para su gestión. |
| **Respaldo y recuperación de datos** | Establecer la responsabilidad sobre la realización de las copias de seguridad. |
| **Continuidad del servicio** | Disponer de una serie de medidas que garanticen la continuidad de las operaciones. |
| **Finalización del contrato** | Regular los aspectos relativos a la devolución de la información, o los relativos a la destrucción de la misma. Siendo imprescindible requerir evidencias (certificados) de su realización. |
| **Transferencia de tecnología** | Una vez finalizado el contrato con el proveedor, éste debe desarrollar las acciones precisas para la transferencia del conocimiento y de la información, implicado en el servicio y determinando un plazo. |
| **Información sobre la subcontratación** | Incluir la obligación de informar sobre las subcontrataciones que se van a realizar y evidenciar que se cumple con las obligaciones requeridas con carácter previo a la contratación. |
| **Requisitos legales** | • Solicitar el certificado de conformidad vigente de la norma de seguridad seguida como puede ser ISO 27001 o el ENS.<br>• Acuerdo de confidencialidad de la información.<br>• Cumplimiento de la normativa vigente en materia de protección de datos. |

| | |
|---|---|
| **Garantías contractuales** | • El encargado del tratamiento debe ofrecer garantías suficientes para aplicar medidas técnicas y organizativas apropiados, de manera que el tratamiento sea conforme con los requisitos del RGPD y garantice la protección de los derechos del interesado.<br>• Debe preverse mecanismos que garanticen el borrado seguro de los datos cuando lo solicite SPIKA TECH y, en todo caso al finalizar el contrato. Ej. Requerir una certificación de la destrucción emitida por el proveedor.<br>• La contratación de servicios en la nube exige garantizar la realización de auditorías de seguridad ordinarias y extraordinarias previstas en la ISO 27001. |
| **Portabilidad e interoperabilidad** | La contratación de servicios en la nube debe garantizar la portabilidad de los datos entre prestadores de servicios y ejercicios de los derechos de acceso por parte de los ciudadanos, mediante el uso de formatos estandarizados de datos que cumplan los requisitos establecidos en el Esquema Nacional de Interoperabilidad:<br><br>• Debe adoptarse medidas organizativas y técnicas necesarias con el fin de garantizar la interoperabilidad en relación con la recuperación y conservación de los documentos electrónicos a lo largo de su ciclo de vida.<br>• Conservación de los documentos electrónicos en el formato en el que hayan sido elaborados, enviados o recibidos, y preferentemente en un formato correspondiente a un estándar abierto que preserve a lo largo del tiempo la integridad del contenido de los documentos, de la firma electrónica y de los metadatos necesarios. |
| **Cláusula de confidencialidad** | El proveedor debe comprometerse a garantizar la confidencialidad utilizando los datos solo para los servicios contratados. Asimismo, el proveedor debe garantizar que el |

| | |
|---|---|
| | personal autorizado a tratar los datos haya suscrito compromisos de confidencialidad. |
| **Condicionantes geográficos** | Establecer condiciones sobre la ubicación geográfica de los servidores y/o de las líneas de comunicaciones en función de la información. Hay que tener en cuenta en qué país el proveedor va a almacenar los datos para identificar si existe una transferencia internacional que requiera la aplicación de medidas adicionales. |
| **Seguimiento de la calidad del servicio** | Regular como se va a realizar el seguimiento de la calidad del servicio del proveedor, definiendo los mecanismos que el proveedor implementará para que SPIKA TECH pueda verificar que los niveles de calidad del servicio se cumplen. |

## 6 REGISTROS Y ARCHIVOS

| Nombre del registro | | Versión y Modificaciones |
|---|---|---|
| **REGISTRO** | **N/A** | N/A |

## 7 REFERENCIAS

- Se cita a continuación la principal regulación aplicable:
  - Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo de 27 de abril de 2016 relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos), en adelante RGPD.
  - Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales, en adelante LOPDGDD.
- ISO/ IEC 27001:2022

- 5.23 Seguridad de la información para el uso de servicios en la nube

- En los procesos de contratación de servicios en la nube, pueden ser aplicables las siguientes guías de referencia del Centro Criptológico Nacional:
  - Guía de Seguridad de las TIC CCN-STIC 823.
- Agencia Española de Protección de datos:
  - Guía para clientes que contraten servicios de Cloud Computing.

# 8 ANEXOS

## 8.1 Relación de medidas de seguridad y el modelo de responsabilidad compartida

A continuación, se recoge en una tabla las modalidades de despliegue y categorías de servicio en la nube teniendo en cuenta los controles **de seguridad** y el modelo de responsabilidad compartida entre **SPIKA TECH** y el proveedor.

| | | Modalidad | | |
|---|---|---|---|---|
| | **Controles aplicables ISO 27001** | **SaaS** | **PaaS** | **IaaS** |
| **Marco organizativo** | **Política de seguridad** | Compartida | Compartida | Compartida |
| | **Normativa de seguridad** | Compartida | Compartida | Compartida |
| | **Procedimientos de seguridad** | Compartida | Compartida | Compartida |
| | **Procesos de autorización** | Compartida | Compartida | Compartida |
| | **Análisis de riesgos** | Proveedor | Compartida | Compartida |

| | | | | |
|---|---|---|---|---|
| Marco operacional | | | | (Si es nube privada on premise, SPIKA TECH) |
| | **Arquitectura de seguridad** | Proveedor | Compartida | Compartida<br><br>(Si es nube privada on premise, SPIKA TECH) |
| | **Adquisición de nuevos componentes** | Compartida | Compartida | Compartida |
| | **Dimensionamiento y capacidad** | Proveedor | Compartida | Compartida |
| | **Componentes certificados** | Proveedor | Proveedor | Proveedor |
| **Control de acceso** | **Control de acceso** | Compartida | Compartida | Compartida |
| **Explotación** | **Inventario de activos** | Proveedor | Compartida | Compartida |
| | **Configuración de seguridad** | Compartida | Compartida | Compartida |
| | **Gestión de la configuración de seguridad** | Compartida | Compartida | Compartida |

| | | | | |
|---|---|---|---|---|
| **Explotación** | **Mantenimiento y actualizaciones de seguridad** | Compartida | Compartida | Compartida |
| | **Gestión de cambios** | Compartida | Compartida | Compartida |
| | **Protección frente a código dañino** | Compartida | Compartida | Compartida |
| | **Gestión de incidentes** | Compartida | Compartida | Compartida |
| | **Registro de la actividad** | Proveedor | Proveedor | Proveedor |
| | **Registro de la gestión de incidentes** | Compartida | Compartida | Compartida |
| | **Protección de claves criptográficas** | Proveedor | Proveedor | Proveedor |
| **Recursos externos** | **Contratación y acuerdos de nivel de servicio** | SPIKA TECH | SPIKA TECH | SPIKA TECH |
| | **Gestión diaria** | SPIKA TECH | SPIKA TECH | SPIKA TECH |
| | **Protección de la cadena de suministro** | Compartida | Compartida | Compartida |
| | **Interconexión de sistemas** | Compartida | Compartida | Compartida |
| **Servicios en la nube** | **Protección de servicios en la nube** | Compartida | Compartida | Compartida |

| | | | | |
|---|---|---|---|---|
| **Continuidad del servicio** | **Análisis de impacto** | SPIKA TECH | SPIKA TECH | SPIKA TECH |
| | **Plan de continuidad** | Proveedor | Proveedor | Proveedor |
| | **Pruebas periódicas** | Proveedor | Proveedor | Proveedor |
| | **Interconexión de sistemas** | Proveedor | Proveedor | Proveedor |
| **Monitorización del sistema** | **Detección de intrusión** | Proveedor | Proveedor | SPIKA TECH |
| | **Sistema de métricas** | Compartida | Compartida | Compartida |
| | **Vigilancia** | Proveedor | Proveedor | SPIKA TECH |
| **Medidas de protección** | **Protección de las instalaciones e infraestructuras** | Proveedor | Proveedor | SPIKA TECH |
| | **Gestión del personal** | Compartida | Compartida | Compartida |
| | **Protección de los equipos** | Compartida | Compartida | Compartida |
| | **Protección de las comunicaciones** | Compartida | Compartida | Compartida |
| | **Protección de los soportes de información** | Compartida | Compartida | Compartida |
| | **Protección de las aplicaciones informáticas** | Compartida | Compartida | Compartida |

| | | | | |
|---|---|---|---|---|
| | **Protección de la información** | Compartida | Compartida | Compartida |
| | **Protección del correo electrónico** | Compartida | Compartida | Compartida |
| | **Protección de servicios y aplicaciones web** | Proveedor | SPIKA TECH | SPIKA TECH |
| | **Protección de la navegación web** | Proveedor | SPIKA TECH | SPIKA TECH |
| | **Protección frente a denegación de servicio** | Proveedor | Proveedor | SPIKA TECH |